



Table Top Exercise (Core)

Olubukola Omotayo
Coding Dojo Cybersecurity Boot Camp
20th December 2023



Tabletop Exercise (Core)



Learning Objectives:

- Given a situation, determine the appropriate action according to incident response procedures.

Answer the 5 questions below for **EACH** of the scenarios below:

1. Who should you notify internally in your organization?
2. Who should you notify external to your organization if any?
3. What resources would you use to resolve the incident?
4. What would be your course of action? How would you recover? (give this in the form of a narrative timeline)
5. How would you prevent (or mitigate) incidents like these in the future?

Scenario #1

An employee casually remarks about how generous it is of state officials to provide the handful of USB drives on the conference room table, embossed with the State logo. After making some inquiries you find there is no state program to provide USB drives to employees. A further investigation subsequently found an unspecified password-stealing keylogger. The spyware was designed to upload stolen usernames and passwords to a server under the control of hackers.

Scenario #2

An employee calls to ask for the password for the Wi-Fi network, indicating they would like to use it on their cell phone so they can check Facebook on their lunch break. You don't have a Wi-Fi network. A scan of the building indicates there are 4 Wi-Fi networks, clearly originating from within government space and broadcasting a variety of names that suggest people are using them for work purposes. In the course of follow-up to this report, it is found that all 4 devices are plugged into your hard-wired network. Two have logging enabled and show that they are being used by employees for official work purposes.

Scenario #3

Upon review of your logs, several of your organization's internet-facing assets are being scanned. After investigation, the scans are originating from what seems to be a legitimate private cyber security company. The private company acknowledges the scans but refuses to disclose any information such as who ordered the scans due to a non-disclosure agreement (NDA). The scans from the same source continue to scan other external-facing assets and the private company still refuses to disclose any information.

Assignment Submission

Upload a single document with answers to all 5 questions for each of the 3 above scenarios. Separate them inside of your document by scenario. Your answers should be a minimum of 2 sentences EACH.

Assignment Solution:

Scenario #1

An employee casually remarks about how generous it is of state officials to provide the handful of USB drives on the conference room table, embossed with the State logo. After making some inquiries you find there is no state program to provide USB drives to employees. A further investigation subsequently found an unspecified password-stealing keylogger. The spyware was designed to upload stolen usernames and passwords to a server under the control of hackers.

1. Who should you notify internally in your organization?

Given the discovery of a password-stealing keylogger and the potential compromise of sensitive information, the following internal notifications should be made:

- **IT Security Team:** Notify the internal IT security team immediately to initiate a thorough investigation and containment efforts.
- **Legal and Compliance Departments:** Inform the legal and compliance departments to assess any potential legal implications, compliance violations, and obligations for reporting.
- **Internal Incident Response Team:** Activate the internal incident response team to coordinate efforts, communication, and the execution of an incident response plan.
- **Human Resources:** Notify the HR department to assess any potential impact on employees, ensure appropriate communication, and address any personnel-related issues.

2. Who should you notify external to your organization if any?

External Notification:

- **Law Enforcement:** Report the incident to relevant law enforcement agencies, providing details about the keylogger, its capabilities, and any evidence of malicious activity. This may serve as an alert about similar attacks in other organizations.
- **State Authorities:** If the incident involves state-related information, contact relevant state authorities or agencies to report the compromise and seek their guidance.
- **Affected Users:** If specific users are identified as potential victims, notify them promptly, advise them to change passwords, and provide guidance on monitoring their accounts for suspicious activity.

3. What resources would you use to resolve the incident?

Resources for Resolution:

- **Cybersecurity Experts:** Engage external cybersecurity experts to assist in the thorough analysis, detection, and removal of the keylogger.
- **Digital Forensics Tools:** Employ digital forensics tools to analyze affected systems, identify the extent of the compromise, and gather evidence for investigative purposes.
- **Network Monitoring Tools:** Utilize network monitoring tools to identify any unusual or malicious network traffic associated with the keylogger.
- **Backup Systems:** Restore affected systems from clean backups to ensure that any compromised data is replaced with a known-good state.

4. What would be your course of action? How would you recover? (give this in the form of a narrative timeline)

Course of Action:

- **Immediate Response (Day 1):**
 - **Isolation:** Isolate affected systems from the network to prevent further data exfiltration.
 - **Notification:** Notify internal stakeholders, law enforcement, and state authorities where applicable.
 - **Engage Experts:** Bring in cybersecurity experts to assist with analysis.
- **Investigation (Days 2-5):**
 - **Forensics:** Conduct digital forensics on affected systems to identify the extent of the compromise.
 - **Analysis:** Analyze logs and network traffic to trace the keylogger's entry and movement.
- **Containment and Eradication (Days 6-10):**
 - **Remove Keylogger:** Use specialized tools to remove the keylogger from all affected systems.



- **Patch Vulnerabilities:** Identify and patch vulnerabilities that allowed the keylogger to infiltrate.
- **Recovery (Days 11-15):**
 - **Restore Systems:** Restore affected systems from clean backups to a known-good state.
 - **Change Passwords:** Ensure that all compromised passwords are reset.
 - **Monitoring:** Implement continuous monitoring for any signs of residual malicious activity.

5. How would you prevent (or mitigate) incidents like these in the future?

Prevention and Mitigation:

- **Security Awareness Training:** Conduct regular security awareness training for employees to educate them about the risks of using unknown USB drives.
- **Endpoint Security Solutions:** Deploy and maintain robust endpoint security solutions, including antivirus and anti-malware tools.
- **USB Drive Policies:** Implement policies restricting the use of external storage devices and educate employees about the risks associated with unverified USB drives.
- **Regular Security Audits:** Conduct regular security audits and penetration testing to identify and address vulnerabilities proactively.
- **Incident Response Plan Review:** Regularly review and update the incident response plan to incorporate lessons learned from each incident and improve the organization's overall security posture.

Scenario #2

An employee calls to ask for the password for the Wi-Fi network, indicating they would like to use it on their cell phone so they can check Facebook on their lunch break. You don't have a Wi-Fi network. A scan of the building indicates there are 4 Wi-Fi networks, clearly originating from within government space and broadcasting a variety of names that suggest people are using them for work purposes. In the course of follow-up to this report, it is found that all 4 devices are plugged into your hard-wired network. Two have logging enabled and show that they are being used by employees for official work purposes.

1. Who should you notify internally in your organization?

Internal Notification:

- **IT Security Team:** Notify the IT security team immediately to investigate the unauthorized Wi-Fi networks and potential network compromise.
- **Network Administration Team:** Inform the network administration team as they are responsible for the hard-wired network infrastructure.
- **Internal Incident Response Team:** Activate the internal incident response team to coordinate efforts and conduct a comprehensive investigation.
- **Human Resources:** Notify HR about the unauthorized use of network resources by employees.

2. Who should you notify external to your organization if any?

External Notification:

- **Law Enforcement:** If there is evidence of malicious activity or a potential security breach, report the incident to law enforcement.
- **Regulatory Authorities:** If the incident involves sensitive information or potential compliance violations, notify relevant regulatory authorities.

3. What resources would you use to resolve the incident?

Resources for Resolution:

- **Network Forensics Tools:** Use network forensics tools to analyze the traffic on the hard-wired network and identify any malicious activity.
- **Network Scanning Tools:** Employ network scanning tools to identify unauthorized Wi-Fi networks and devices connected to the network.
- **Legal and Compliance Experts:** Engage legal and compliance experts to assess potential legal implications and regulatory compliance issues.

4. What would be your course of action? How would you recover? (give this in the form of a narrative timeline)

Course of Action (Narrative Timeline):

- **Immediate Response (Day 1):**
 - **Isolate Unauthorized Devices:** Immediately disconnect the unauthorized Wi-Fi devices from the hard-wired network.
 - **Notification:** Notify internal teams, including IT security, network administration, incident response, and HR.
 - **Documentation:** Document details of the incident, including devices involved, network activity, and any potential security risks.
- **Investigation (Days 2-5):**
 - **Forensic Analysis:** Conduct forensic analysis on the unauthorized devices to determine the extent of the compromise.
 - **Interview Employees:** Interview employees associated with the devices to understand their reasons for setting up unauthorized Wi-Fi networks.
 - **Documentation:** Maintain a detailed record of the investigation, findings, and actions taken.
- **Containment and Eradication (Days 6-10):**
 - **Security Measures:** Strengthen security measures to prevent unauthorized Wi-Fi networks, including network segmentation and improved access controls.
 - **Employee Training:** Conduct training sessions to educate employees about the risks of setting up unauthorized networks and using unauthorized devices on the network.

- **Recovery (Days 11-15):**
 - **Secure Network Configuration:** Review and enhance network configurations to prevent future unauthorized network setups.
 - **Employee Discipline:** Implement appropriate disciplinary actions for employees who violated network security policies.
 - **Continuous Monitoring:** Establish continuous monitoring of network activities to quickly identify and address any suspicious behavior.

5. How would you prevent (or mitigate) incidents like these in the future?

Prevention and Mitigation:

- **Network Security Policies:** Develop and enforce clear policies regarding the use of Wi-Fi networks within the organization.
- **Employee Education:** Regularly educate employees on the importance of network security and the risks associated with unauthorized network setups.
- **Network Segmentation:** Implement network segmentation to limit the impact of unauthorized devices and network setups.
- **Regular Audits:** Conduct regular audits of network infrastructure to identify and address potential security risks proactively.

Scenario #3

Upon review of your logs, several of your organization's internet-facing assets are being scanned. After investigation, the scans are originating from what seems to be a legitimate private cyber security company. The private company acknowledges the scans but refuses to disclose any information such as who ordered the scans due to a non-disclosure agreement (NDA). The scans from the same source continue to scan other external-facing assets and the private company still refuses to disclose any information.

1. Who should you notify internally in your organization?

Internal Notification:

- **IT Security Team:** Notify the IT security team immediately to assess the nature and potential impact of the scans.
- **Legal and Compliance Departments:** Involve legal and compliance departments to understand the legal implications and potential courses of action.
- **Senior Management:** Inform senior management about the ongoing scans and the involvement of a private cybersecurity company.

2. Who should you notify external to your organization if any?

External Notification:

- **Law Enforcement:** Report the incident to law enforcement agencies, providing details about the ongoing scans and the refusal of the private company to disclose information.
- **Industry Regulatory Bodies:** If applicable, notify relevant industry regulatory bodies about the incident and seek guidance.

3. What resources would you use to resolve the incident?

Resources for Resolution:

- **Forensic Analysis Tools:** Utilize forensic analysis tools to assess the impact of the scans on the organization's assets.

- **Legal Experts:** Engage legal experts to review contracts, agreements, and applicable laws regarding unauthorized scanning activities.
- **Incident Response Team:** Activate the incident response team to coordinate efforts and establish a plan for dealing with ongoing scans.

4. What would be your course of action? How would you recover? (give this in the form of a narrative timeline)

Course of Action (Narrative Timeline):

- **Immediate Response (Day 1):**
 - **Log and Document:** Log details of the scans, including source IP addresses, times, and affected assets. Document all communication with the private cybersecurity company.
 - **Notify Internal Teams:** Inform IT security, legal, compliance, and senior management teams about the ongoing scans and the involvement of the private company.
- **Investigation (Days 2-5):**
 - **Forensic Analysis:** Conduct forensic analysis to understand the nature and potential impact of the scans on the organization's assets.
 - **Legal Review:** Engage legal experts to review contracts, NDAs, and relevant laws to determine the organization's rights and courses of action.
 - **Communication with Private Company:** Continue communication with the private company, urging them to disclose information about the scans.
- **Legal Action and Remediation (Days 6-15):**
 - **Legal Action:** Initiate legal actions, if necessary, to compel the private company to disclose information about the scans.
 - **Remediation:** Implement necessary remediation measures to secure internet-facing assets from unauthorized scanning activities.
- **Continuous Monitoring and Reporting (Beyond Day 15):**
 - **Continuous Monitoring:** Enhance monitoring of internet-facing assets to detect and respond to any future unauthorized scanning activities.
 - **Reporting:** Provide regular reports to senior management, legal, and regulatory bodies regarding the incident, actions taken, and preventive measures implemented.

5. How would you prevent (or mitigate) incidents like these in the future?

Prevention and Mitigation:

- **Clarify Policies and Agreements:** Review and clarify policies and agreements with third-party security companies, ensuring that their activities align with the organization's security policies.
- **Incident Response Planning:** Enhance incident response plans to include procedures for dealing with unauthorized scanning activities, involving legal and regulatory bodies as needed.
- **Continuous Communication:** Establish open communication channels with third-party security companies, emphasizing the importance of disclosure in case of activities affecting the organization's assets.

By following this incident response plan, the organization can address the ongoing scans, take legal action if necessary, and implement preventive measures to mitigate the risk of similar incidents in the future.